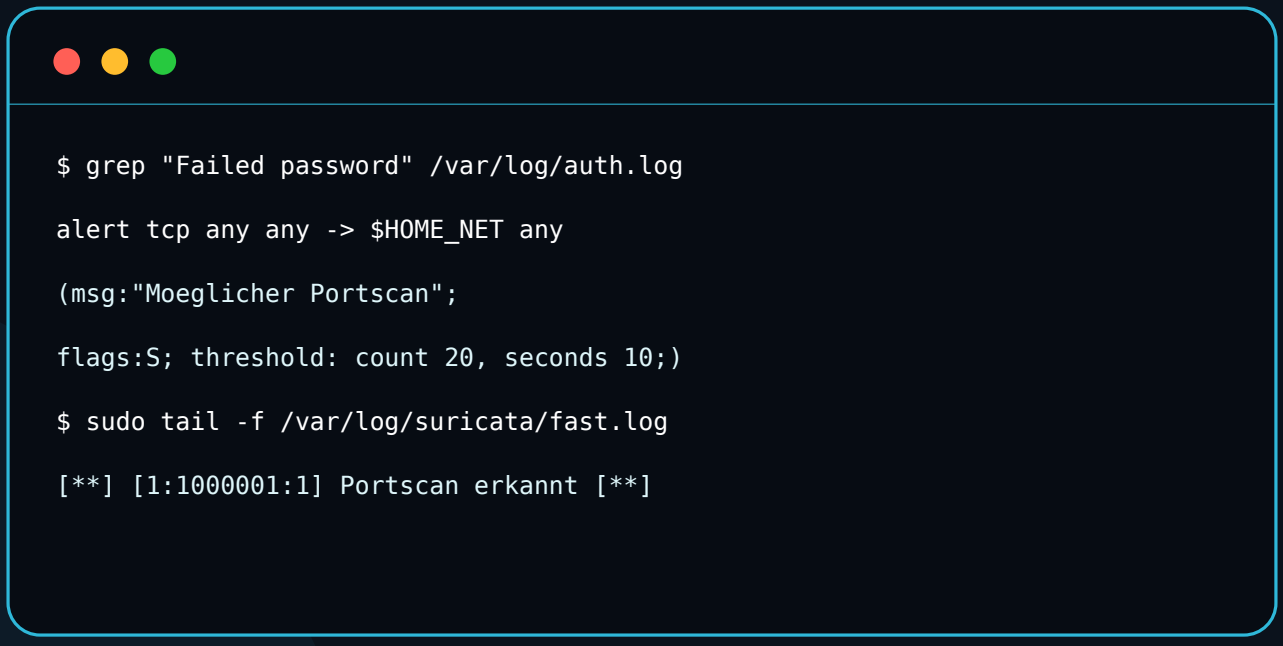
PRAXISHANDBUCH

Blue Team & Defense

Angriffe erkennen, verstehen und abwehren – die Gegenseite dieser Buchreihe



DIESELBEN SPUREN. DIESMAL AUS DER ANDEREN RICHTUNG GELESEN.

Mit Übungen, Spickzettel, Glossar und Index · Ausgabe Oktober 2026

Blue Team & Defense

Angriffe erkennen, verstehen und abwehren – die Gegenseite dieser Buchreihe

Von Logging und SIEM über Intrusion Detection bis zu Incident Response und Hardening. Mit geführten Übungen gegen die eigenen Angriffe dieser Reihe, Spickzettel und Index.

Inhaltsverzeichnis

Vorwort 5

Für wen ist dieses Handbuch? 5

Aufbau 6

Kapitel 1: Was ist Blue Team? 7

1.1 Drei Farben, drei Perspektiven 7

1.2 Typische Blue-Team-Rollen 7

1.3 Warum beide Seiten voneinander profitieren 7

1.4 Die Grenze bleibt dieselbe 8

Zusammenfassung 8

Kapitel 2: Grundlagen – Defense in Depth, Kill Chain und MITRE ATT&CK; 9

2.1 Defense in Depth: mehrere Schichten statt einer Mauer 9

2.2 Die Kill Chain aus Verteidigersicht 9

2.3 MITRE ATT&CK;: eine gemeinsame Sprache 10

Zusammenfassung 10

Kapitel 3: Installation und Laborumgebung 11

3.1 Eine dritte Rolle im bestehenden Labor 11

3.2 Suricata installieren 11

3.3 Ein einfaches Log-Aggregationswerkzeug 11

3.4 Verbindung zu den anderen Büchern dieser Reihe 12

Zusammenfassung 12

Kapitel 4: Logging-Grundlagen 13

4.1 Was überhaupt protokolliert wird 13

4.2 Ein Systemprotokoll gezielt lesen 13

4.3 Webserver-Logs auf Scans untersuchen 13

4.4 Verfügbarkeit ist nicht dasselbe wie Auswertbarkeit 14

Zusammenfassung 14

Kapitel 5: SIEM und Log-Aggregation 15

5.1 Warum verstreute Logs nicht ausreichen 15

5.2 Grundsätzlicher Aufbau 15

5.3 Eine gezielte Suchabfrage formulieren 15

5.4 Von der Abfrage zum automatisierten Alarm 16

Zusammenfassung . . . 16

Kapitel 6: Intrusion Detection mit Suricata . . . 17

6.1 Zwei Erkennungsansätze . . . 17

6.2 Aufbau einer Suricata-Regel . . . 17

6.3 Eine Regel gegen einen bekannten SYN-Flood . . . 18

6.4 Alarme einsehen . . . 18

Zusammenfassung . . . 18

Kapitel 7: Die Angriffe dieser Reihe wiedererkennen . . . 19

7.1 hping3: SYN-Scans und Floods . . . 19

7.2 Nmap: Scan-Geschwindigkeit als Erkennungsmerkmal . . . 19

7.3 Brute-Force: Login-Versuche über SSH, Web oder Metasploit-Auxiliary . . . 19

7.4 Metasploit: ein Exploit-Versuch im Log . . . 19

7.5 Burp Suite: SQL-Injection und XSS im Webserver-Log . . . 20

7.6 Warum manche Techniken schwerer zu erkennen sind . . . 20

Zusammenfassung . . . 20

Kapitel 8: Incident Response – Phasen und Playbooks . . . 21

8.1 Die sechs Phasen . . . 21

8.2 Ein einfaches Playbook erstellen . . . 21

8.3 Dokumentation beginnt während des Vorfalls . . . 22

Zusammenfassung . . . 22

Kapitel 9: Hardening – Systeme absichtlich widerstandsfähiger machen . . . 23

9.1 Das Minimalprinzip . . . 23

9.2 SSH gezielt härten . . . 23

9.3 Hardening gegen die anderen Bände dieser Reihe . . . 24

Zusammenfassung . . . 24

Kapitel 10: Praxisteil – Laboraufbau und geführte Übungen . . . 25

10.1 Laboraufbau . . . 25

10.2 Checkliste: sichere Laborumgebung . . . 25

10.3 Übungen . . . 25

Zusammenfassung . . . 27

Kapitel 11: Troubleshooting, Spickzettel, Glossar und Ressourcen . . . 28

11.1 Häufige Probleme . . . 28

11.2 Spickzettel . . . 28

11.3 Glossar 29
11.4 Weiterführende Ressourcen 29
Zusammenfassung 29

Verzeichnis der Befehlsbeispiele 31

Index 32

Vorwort

Neun Bände dieser Reihe haben bisher eine gemeinsame Blickrichtung: die des Angreifers. hping3 erzeugt Pakete, Nmap erkundet Netzwerke, Metasploit nutzt Schwachstellen aus, Burp Suite prüft Webanwendungen. Dieses Buch dreht die Blickrichtung um. Es fragt nicht, wie ein Angriff gelingt, sondern wie er **auffällt**: in welchem Log, mit welchem Muster, zu welchem Zeitpunkt.

Blue Team bezeichnet die Verteidigerseite der IT-Sicherheit: Monitoring, Logging, Erkennung, Reaktion und Härtung. Jedes der vorherigen Bücher hat eine sichtbare Spur hinterlassen – einen SYN-Flood, einen Nmap-Scan, einen Brute-Force-Versuch, einen erfolgreichen Exploit. Dieses Buch zeigt, wie diese Spuren sichtbar gemacht, gesammelt und ausgewertet werden, bevor aus einem Versuch ein Schaden wird.

> **Gut zu wissen**
>
> Dieses Buch unterscheidet sich von den vorherigen Bänden in einem wichtigen Punkt: Die hier gezeigten Techniken dienen dem Schutz, nicht dem Angriff. Die übliche Beschränkung auf eine isolierte Laborumgebung gilt trotzdem weiter, weil auch Monitoring- und Logging-Systeme selbst Schwachstellen haben können und weil das Mitschneiden fremden Datenverkehrs ohne Berechtigung unabhängig vom Zweck rechtlich problematisch bleibt (Wireshark-Handbuch, Kapitel 1.4).

Für wen ist dieses Handbuch?

Du bist hier richtig, wenn du

- die neun vorherigen Bände dieser Reihe kennst und wissen willst, wie sich jede dort gezeigte Technik aus Verteidigersicht erkennen lässt,
- als angehende Fachkraft für Systemintegration auch die administrative, überwachende Seite der IT-Sicherheit verstehen willst,
- ein eigenes Netzwerk oder eigene Systeme systematisch überwachen und härten möchtest,
- dich auf Zertifizierungen vorbereitest, in denen Detection und Incident Response eigene Schwerpunkte bilden (CompTIA Security+/CySA+, eJPT).

Aufbau

Kapitel	Thema
1	Was ist Blue Team? Abgrenzung zu Red Team und Purple Team
2	Grundlagen: Defense in Depth, die Kill Chain aus Verteidigersicht, MITRE ATT&CK
3	Installation und Laborumgebung
4	Logging-Grundlagen: welche Quellen, welches Format
5	SIEM und Log-Aggregation
6	Intrusion Detection mit Suricata
7	Die Angriffe dieser Reihe wiedererkennen
8	Incident Response: Phasen und Playbooks
9	Hardening: Systeme absichtlich widerstandsfähiger machen
10	Praxisteil: Laboraufbau und geführte Übungen
11	Troubleshooting, Spickzettel, Glossar und Ressourcen

> **TIPP – Profi-Trick**
>
> Kapitel 7 ist der eigentliche Kern dieses Buches: Es nimmt konkrete Beispiele aus dem hping3-, Nmap-, Metasploit- und John-the-Ripper-/Hashcat-Handbuch und zeigt, wie genau dieselbe Technik in einem Log oder einer Erkennungsregel sichtbar wird.

Kapitel 1: Was ist Blue Team?

Lernziele

- Du kannst Blue Team, Red Team und Purple Team klar voneinander abgrenzen.
- Du kennst die typischen Rollen und Aufgaben einer Verteidigungsfunktion.
- Du verstehst, warum beide Seiten voneinander profitieren, statt Gegner zu sein.

1.1 Drei Farben, drei Perspektiven

Team	Aufgabe
Red Team	simuliert Angriffe, um Schwachstellen aufzudecken (Gegenstand der Bände 1-9 dieser Reihe)
Blue Team	überwacht, erkennt und reagiert auf tatsächliche oder simulierte Angriffe
Purple Team	arbeitet bewusst aus beiden Perspektiven zusammen, um Erkennung und Angriff wechselseitig zu verbessern

Gut zu wissen

Der Name „Blue Team" stammt aus militärischen Übungsszenarien, in denen die verteidigende Seite traditionell blau markiert wird, die angreifende rot. Die Begriffe haben sich seit den 1990er-Jahren in der IT-Sicherheit etabliert und bezeichnen heute Funktionen statt Uniformfarben.

1.2 Typische Blue-Team-Rollen

Rolle	Schwerpunkt
SOC-Analyst (Security Operations Center)	überwacht laufend Alarme und Protokolle
Detection Engineer	entwickelt und pflegt Erkennungsregeln (Kapitel 6)
Incident Responder	übernimmt die Reaktion auf einen erkannten Vorfall (Kapitel 8)
Security Administrator	härtet Systeme präventiv (Kapitel 9)

In kleineren Organisationen übernimmt oft eine einzelne Fachkraft mehrere dieser Rollen gleichzeitig – genau die Situation, auf die dieses Buch mit seinem Praxisteil zielt.

1.3 Warum beide Seiten voneinander profitieren

Beispiel 1.1: Der Kreislauf zwischen Red und Blue (Konzept)

```
Red Team findet eine Lücke  -> Blue Team lernt, sie zu erkennen
Blue Team verbessert Erkennung -> Red Team muss sich anpassen, um unentdeckt zu bleiben
-> Beide Seiten treiben sich gegenseitig zu höherer Qualität an
```

TIPP – Profi-Trick

Die Werkzeuge der vorherigen Bände dieser Reihe sind aus Blue-Team-Sicht keine Gegner, sondern Trainingspartner: Ein selbst ausgeführter hping3-SYN-Flood oder Nmap-Scan im eigenen Labor erzeugt genau die Spuren, an denen du in diesem Buch lernst, eine echte Erkennung aufzubauen.

1.4 Die Grenze bleibt dieselbe

LEGAL – nur mit Auftrag/Einwilligung

Monitoring, Logging und Erkennung betreffen oft personenbezogene Daten – wer wann welche Webseite aufgerufen oder sich wo angemeldet hat. In einem Unternehmenskontext braucht die Überwachung von Mitarbeitenden in Deutschland eine klare rechtliche Grundlage und in der Regel die Einbeziehung des Betriebsrats sowie die Beachtung der DSGVO. Für die Übungen in diesem Buch gilt deshalb dieselbe Regel wie in der gesamten Reihe: ausschließlich im eigenen, dafür vorgesehenen Labor.

Zusammenfassung

Zusammenfassung

- Red Team greift an, Blue Team verteidigt, Purple Team verbindet beide Perspektiven bewusst.
- SOC-Analyst, Detection Engineer, Incident Responder und Security Administrator sind typische Blue-Team-Rollen.
- Red und Blue Team treiben sich im Idealfall gegenseitig zu höherer Qualität an, statt reine Gegner zu sein.
- Monitoring betrifft oft personenbezogene Daten und braucht in einem Unternehmenskontext eine klare rechtliche Grundlage.

Kapitel 2: Grundlagen – Defense in Depth, Kill Chain und MITRE ATT&CK

Lernziele

- Du verstehst das Prinzip der gestaffelten Verteidigung.
- Du kannst die Kill Chain aus Verteidigersicht lesen, statt nur aus Angreifersicht.
- Du kennst Aufbau und Zweck von MITRE ATT&CK als gemeinsame Sprache.

2.1 Defense in Depth: mehrere Schichten statt einer Mauer

Defense in Depth bedeutet, Sicherheit nicht auf eine einzelne Barriere zu verlassen, sondern mehrere, unabhängig wirkende Schichten hintereinanderzuschalten – fällt eine Schicht aus, greift die nächste.

Beispiel 2.1: Typische Schichten (Konzept)

```
Netzwerk-Firewall  -> Intrusion Detection (Kapitel 6) -> Host-Härtung (Kapitel 9)
-> Protokollierung und Überwachung (Kapitel 4-5) -> Reaktionsfähigkeit (Kapitel 8)
```

Gut zu wissen

Kein einzelnes Werkzeug aus dieser Reihe ersetzt eine andere Schicht. Eine gut konfigurierte Firewall verhindert nicht jeden erfolgreichen Phishing-Versuch, ein gutes Erkennungssystem verhindert nicht jede Fehlkonfiguration (OWASP-Handbuch, Kapitel 4) – das ist der Grund, warum Defense in Depth mehrere, unterschiedliche Schichten vorsieht.

2.2 Die Kill Chain aus Verteidigersicht

Das Ethical-Hacking-Handbuch (Kapitel 3) beschreibt die Kill Chain aus Angreiferperspektive: Reconnaissance, Weaponization, Delivery, Exploitation, Installation, Command & Control, Actions on Objectives. Aus Verteidigersicht liest sich dieselbe Kette anders: An jedem einzelnen Glied besteht eine eigenständige Chance, den Ablauf zu unterbrechen.

Beispiel 2.2: Dieselbe Kette, umgekehrt gelesen

```
Reconnaissance    -> wird ein Scan überhaupt bemerkt? (Kapitel 6-7)
Delivery          -> wird eine verdächtige Datei abgefangen?
Exploitation      -> wird der Exploit-Versuch protokolliert? (Kapitel 4-5)
Installation      -> fällt eine neue, unbekannte Datei oder ein neuer Dienst auf?
Command & Control -> fällt ungewöhnlicher ausgehender Datenverkehr auf?
```

TIPP – Profi-Trick

Je früher in dieser Kette ein Angriff erkannt wird, desto geringer in der Regel der entstandene Schaden. Ein Scan in der Reconnaissance-Phase zu bemerken ist deutlich weniger aufwendig als einen bereits laufenden Command-and-Control-Kanal zu entdecken.

2.3 MITRE ATT&CK: eine gemeinsame Sprache

MITRE ATT&CK ist eine öffentlich gepflegte, strukturierte Wissensbasis bekannter Angreifertechniken, gegliedert nach Taktiken (das übergeordnete Ziel, z. B. „Persistence") und darunter eingeordneten, konkreten Techniken (z. B. „Scheduled Task/Job" – vergleiche die Cron-Techniken aus dem Linux-PrivEsc-Handbuch, Kapitel 7).

Beispiel 2.3: Eine ATT&CK-Technik nachschlagen (Konzept)

```
Taktik:    Persistence
Technik:   T1053 - Scheduled Task/Job
Erkennung: ungewöhnliche neue Einträge in /etc/crontab überwachen
```

> **Gut zu wissen**
>
> MITRE ATT&CK dient Blue Teams dazu, Erkennungsregeln systematisch gegen bekannte Techniken statt nur gegen Einzelfälle aufzubauen, und Red Teams dazu, ihre eigene Methodik gegen dieselbe, anerkannte Referenz zu dokumentieren.

Zusammenfassung

> **Zusammenfassung**
>
> - Defense in Depth setzt auf mehrere, unabhängige Sicherheitsschichten statt auf eine einzelne Barriere.
> - Jedes Glied der Kill Chain bietet eine eigenständige Chance, einen Angriff zu unterbrechen.
> - MITRE ATT&CK strukturiert bekannte Angreifertechniken nach Taktiken und konkreten Techniken.
> - ATT&CK dient als gemeinsame Sprache zwischen Red und Blue Team.

Kapitel 3: Installation und Laborumgebung

Lernziele

- Du richtest eine zusätzliche Blue-Team-VM in deinem bestehenden Labor ein.
- Du installierst Suricata und ein einfaches Log-Aggregationswerkzeug.
- Du verbindest diese VM mit den bereits vorhandenen Angreifer- und Zielsystemen.

3.1 Eine dritte Rolle im bestehenden Labor

Das Labor dieser Reihe bestand bisher aus zwei Rollen: Kali als Angreifer, Metasploitable als Ziel. Dieses Buch ergänzt eine dritte: eine **Monitoring-VM**, die denselben Netzwerkverkehr beobachtet, den die anderen Bücher bereits erzeugt haben.

Beispiel 3.1: Laboraufbau für dieses Buch (Konzept)

```
Kali-VM (Angreifer)       -- Internal Network --
Metasploitable-VM (Ziel)  -- Internal Network --
Neue Monitoring-VM        -- Internal Network, zusätzlich mit Monitoring-Interface
```

TIPP – Profi-Trick

Für die Monitoring-VM genügt eine schlanke Debian- oder Ubuntu-Server-Installation. Richte eine zweite Netzwerkschnittstelle im Promiscuous Mode ein (Wireshark-Handbuch, Kapitel 2.2), damit die VM denselben Verkehr sieht wie ein Mitschnitt mit Wireshark.

3.2 Suricata installieren

Beispiel 3.2: Suricata auf der Monitoring-VM installieren

```
$ sudo apt update && sudo apt install suricata
$ sudo suricata-update
```

`suricata-update` lädt einen aktuellen Satz an Erkennungsregeln herunter, vergleichbar mit den NSE-Skripten aus dem Nmap-Handbuch (Kapitel 7), nur für die laufende Verkehrsüberwachung statt für einen einmaligen Scan.

3.3 Ein einfaches Log-Aggregationswerkzeug

Beispiel 3.3: rsyslog als zentralen Log-Sammelpunkt einrichten (Konzept)

```
# Auf der Metasploitable-VM: Logs an die Monitoring-VM weiterleiten
*.* @<monitoring-vm-ip>:514
```

Für den Einstieg reicht die Weiterleitung über das klassische `syslog`-Protokoll aus. Kapitel 5 vertieft, wie daraus ein durchsuchbares, strukturiertes SIEM-System wird.

3.4 Verbindung zu den anderen Büchern dieser Reihe

Gut zu wissen

Diese Monitoring-VM beobachtet genau den Verkehr, den du in den Übungen der anderen Bände bereits erzeugt hast: einen hping3-SYN-Flood, einen Nmap-Scan, einen Metasploit-Exploit-Versuch. Für dieses Buch brauchst du diese Übungen nicht zu wiederholen – es reicht, sie erneut auszuführen, während die Monitoring-VM mitschneidet.

LEGAL – nur mit Auftrag/Einwilligung

Dieselbe Netzwerkisolation wie in den anderen Büchern dieser Reihe gilt unverändert: Internal Network ohne Internetzugang, alle drei VMs ausschließlich im eigenen Labor (Ethical-Hacking-Handbuch, Kapitel 9).

Zusammenfassung

Zusammenfassung

- Eine zusätzliche Monitoring-VM ergänzt das bestehende Labor um die Verteidigerperspektive.
- Suricata übernimmt die Intrusion Detection, `suricata-update` lädt aktuelle Erkennungsregeln.
- Eine einfache syslog-Weiterleitung ist der erste Schritt zu einem zentralen Log-Sammelpunkt.
- Dieselben Übungen aus den anderen Büchern lassen sich wiederholen, diesmal mit aktiver Beobachtung.

Kapitel 4: Logging-Grundlagen

Lernziele

- Du kennst die wichtigsten Log-Quellen eines typischen Systems.
- Du kannst ein Linux-Systemprotokoll gezielt nach relevanten Ereignissen durchsuchen.
- Du verstehst den Unterschied zwischen Verfügbarkeit und Auswertbarkeit eines Logs.

4.1 Was überhaupt protokolliert wird

Quelle	Typischer Inhalt
Systemprotokoll (`/var/log/syslog`, `/var/log/auth.log`)	Anmeldungen, sudo-Aufrufe, Systemdienste
Webserver-Logs (`access.log`, `error.log`)	jede HTTP-Anfrage mit Quelle, Pfad und Statuscode
Firewall-Logs	zugelassene und blockierte Verbindungen
Anwendungslogs	anwendungsspezifische Ereignisse, z. B. fehlgeschlagene Logins einer Webanwendung
Suricata-Alarme (Kapitel 6)	durch Signaturen ausgelöste Erkennungsereignisse

4.2 Ein Systemprotokoll gezielt lesen

Beispiel 4.1: Fehlgeschlagene Anmeldeversuche finden

```
$ grep "Failed password" /var/log/auth.log
```

Beispiel 4.2: sudo-Nutzung nachvollziehen

```
$ grep "sudo:" /var/log/auth.log
```

Gut zu wissen

Dieselbe Auswertung, die du hier in einem Systemprotokoll vornimmst, entspricht aus Angreiferperspektive genau dem, was ein Brute-Force-Versuch mit Hydra oder dem Burp-Suite-Intruder im Hintergrund erzeugt (Burp-Suite-Handbuch, Kapitel 6; Ethical-Hacking-Handbuch, Kapitel 6.4): eine Serie von Fehlversuchen in kurzer Zeit.

4.3 Webserver-Logs auf Scans untersuchen

Beispiel 4.3: Auffällige Zugriffsmuster im Webserver-Log

```
$ grep -E "union select|'.*or.*'1'='1" /var/log/apache2/access.log
```

Dieses Muster entspricht genau den SQL-Injection-Testwerten aus dem Ethical-Hacking- und Burp-Suite-Handbuch – was dort als Angriffstechnik gezeigt wird, hinterlässt hier eine konkrete, auswertbare Spur.

4.4 Verfügbarkeit ist nicht dasselbe wie Auswertbarkeit

WARNUNG – Sicherheitsrisiko

Ein Log, das lediglich existiert, aber nie gelesen wird, schützt niemanden – genau das beschreibt die OWASP-Kategorie „Logging and Alerting Failures" (OWASP-Handbuch, Kapitel 8.4). Ein vorhandenes Protokoll ist nur der erste Schritt; erst die regelmäßige oder automatisierte Auswertung macht daraus einen tatsächlichen Schutz.

Zustand	Beispiel	Schutzwirkung
Kein Logging	Ereignis entsteht, wird nirgends festgehalten	keine
Logging ohne Auswertung	Ereignis wird protokolliert, aber nie angesehen	praktisch keine
Logging mit regelmäßiger Auswertung	Protokoll wird manuell oder automatisiert geprüft	vorhanden, abhängig von Prüffrequenz
Logging mit Echtzeit-Alarmierung	ein System meldet aktiv auffällige Muster (Kapitel 5-6)	am höchsten

Zusammenfassung

Zusammenfassung

- System-, Webserver-, Firewall- und Anwendungslogs decken gemeinsam die wichtigsten Ereignisquellen ab.
- Fehlgeschlagene Logins und sudo-Nutzung lassen sich gezielt mit `grep` aus dem Systemprotokoll herausfiltern.
- Angriffsmuster wie SQL-Injection-Versuche hinterlassen eine konkrete, im Webserver-Log auffindbare Spur.
- Ein Log ohne regelmäßige Auswertung bietet praktisch keinen Schutz, unabhängig davon, wie vollständig es ist.

Kapitel 5: SIEM und Log-Aggregation

Lernziele

- Du verstehst den Zweck eines SIEM gegenüber verstreuten Einzel-Logs.
- Du kennst den grundsätzlichen Aufbau eines Log-Aggregationssystems.
- Du formulierst eine einfache, gezielte Suchabfrage.

5.1 Warum verstreute Logs nicht ausreichen

Ein typisches Netzwerk erzeugt Protokolle an vielen verschiedenen Stellen gleichzeitig: jeder Server, jede Firewall, jeder Webdienst führt sein eigenes Log. Ein Angriff, der sich über mehrere Systeme erstreckt, lässt sich aus einem einzelnen dieser Logs oft gar nicht erkennen.

Beispiel 5.1: Warum ein verteilter Angriff in Einzel-Logs unsichtbar bleibt (Konzept)

```
Firewall-Log:     zeigt nur, dass ein Port erreicht wurde
Webserver-Log:    zeigt nur HTTP-Anfragen, ohne Netzwerkkontext
System-Log:       zeigt nur lokale Anmeldungen, ohne Bezug zum Webserver
-> Erst alle drei zusammen zeigen den vollständigen Ablauf eines Angriffs
```

Ein **SIEM** (Security Information and Event Management) sammelt genau diese verstreuten Quellen an einem zentralen Ort und macht sie gemeinsam durchsuchbar.

5.2 Grundsätzlicher Aufbau

Beispiel 5.2: Die drei Grundbestandteile eines SIEM (Konzept)

```
Sammlung    -> Logs von allen Quellen zentral einsammeln (Kapitel 3.3, syslog-Weiterleitung)
Normalisierung -> unterschiedliche Formate in eine einheitliche Struktur bringen
Auswertung  -> durchsuchen, korrelieren, Alarme auslösen
```

Gut zu wissen

Verbreitete, kostenlose SIEM-Lösungen sind der **Elastic Stack** (Elasticsearch, Logstash, Kibana, oft kurz „ELK" genannt) und **Wazuh**, das zusätzlich eigene Host-basierte Erkennungsfunktionen mitbringt. Beide lassen sich auf derselben Monitoring-VM aus Kapitel 3 betreiben.

5.3 Eine gezielte Suchabfrage formulieren

Beispiel 5.3: Mehrere fehlgeschlagene Logins von derselben Quelle finden (Konzept)

```
Suche: event_type:"auth_failure" AND source_ip:"192.168.56.101"
Zeitraum: letzte 5 Minuten
```

TIPP – Profi-Trick

Eine gute SIEM-Abfrage folgt demselben Prinzip wie ein guter Display-Filter in Wireshark (Wireshark-Handbuch, Kapitel 5): erst grob eingrenzen (Zeitraum, Quelle), dann gezielt nach dem konkreten Muster suchen, statt den gesamten Datenbestand auf einmal zu durchsuchen.

5.4 Von der Abfrage zum automatisierten Alarm

Beispiel 5.4: Eine Abfrage in eine wiederkehrende Regel umwandeln (Konzept)

```
Wenn: mehr als 5 "auth_failure"-Ereignisse derselben Quelle in 5 Minuten
Dann: Alarm auslösen und für die spätere Auswertung markieren
```

Genau diese Umwandlung – von einer einmal gestellten Frage zu einer dauerhaft laufenden Regel – ist der Kern dessen, was ein SIEM von einem bloßen Log-Archiv unterscheidet.

Zusammenfassung

Zusammenfassung

- Ein SIEM sammelt verstreute Logs zentral, damit sich verteilte Angriffe überhaupt erkennen lassen.
- Sammlung, Normalisierung und Auswertung sind die drei Grundbestandteile jedes SIEM.
- Elastic Stack und Wazuh sind verbreitete, kostenlose Lösungen für den eigenen Laboraufbau.
- Eine wiederkehrende Suchabfrage lässt sich in eine automatisiert auslösende Alarmregel umwandeln.

Kapitel 6: Intrusion Detection mit Suricata

Lernziele

- Du verstehst den Unterschied zwischen signaturbasierter und anomaliebasierter Erkennung.
- Du liest eine Suricata-Regel und verstehst ihren Aufbau.
- Du schreibst eine eigene, einfache Erkennungsregel.

6.1 Zwei Erkennungsansätze

Ansatz	Grundidee	Stärke	Schwäche
Signaturbasiert	vergleicht Verkehr mit bekannten, dokumentierten Mustern	zuverlässig bei bekannten Angriffen	erkennt unbekannte, neue Muster nicht
Anomaliebasiert	lernt normales Verhalten und meldet Abweichungen	kann auch unbekannte Muster erkennen	neigt zu mehr Fehlalarmen

Suricata arbeitet primär signaturbasiert – dasselbe Grundprinzip wie die NSE-Skripte aus dem Nmap-Handbuch (Kapitel 7) oder die Hash-Signaturen von Antivirensoftware, nur auf Netzwerkverkehr angewendet.

6.2 Aufbau einer Suricata-Regel

Beispiel 6.1: Eine Regel zur Erkennung eines Nmap-SYN-Scans (Konzept)

```
alert tcp any any -> $HOME_NET any (msg:"Möglicher Nmap SYN-Scan erkannt"; \
  flags:S; threshold:type threshold, track by_src, count 20, seconds 10; \
  sid:1000001; rev:1;)
```

Bestandteil	Bedeutung
`alert`	Aktion bei Treffer (alternativ `drop`, `pass`)
`tcp any any -> $HOME_NET any`	Protokoll, Quelle und Ziel
`flags:S`	nur Pakete mit gesetztem SYN-Flag (hping3-Handbuch, Kapitel 2.2)
`threshold:...count 20, seconds 10`	löst erst aus, wenn mindestens 20 solcher Pakete binnen 10 Sekunden von derselben Quelle kommen
`sid`	eindeutige Regel-ID

Gut zu wissen

`threshold` ist hier entscheidend: Ohne diese Einschränkung würde die Regel bei **jedem einzelnen** SYN-Paket auslösen, auch bei völlig normalem Verbindungsaufbau. Erst die Häufung innerhalb eines kurzen Zeitfensters unterscheidet einen Scan von gewöhnlichem Verkehr.

6.3 Eine Regel gegen einen bekannten SYN-Flood

Beispiel 6.2: Eine Regel zur Erkennung eines SYN-Floods (Konzept, vergleiche hping3-Handbuch, Kapitel 8)

```
alert tcp any any -> $HOME_NET any (msg:"Möglicher SYN-Flood erkannt"; \
  flags:S; threshold:type threshold, track by_src, count 100, seconds 5; \
  sid:1000002; rev:1;)
```

Dieselbe Grundstruktur wie Beispiel 6.1, nur mit einem deutlich höheren Schwellenwert – angepasst an das erwartete Verkehrsvolumen eines Floods statt eines gewöhnlichen Scans.

6.4 Alarme einsehen

Beispiel 6.3: Suricata-Alarme live verfolgen

```
$ sudo tail -f /var/log/suricata/fast.log
```

TIPP – Profi-Trick

Teste jede neue Regel zunächst mit einem bewusst erzeugten, bekannten Auslöser (z. B. einem Nmap-Scan aus deinem eigenen Kali-Labor) und prüfe, ob der erwartete Alarm tatsächlich erscheint, bevor du dich im Ernstfall auf die Regel verlässt.

Zusammenfassung

Zusammenfassung

- Signaturbasierte Erkennung vergleicht Verkehr mit bekannten Mustern, anomaliebasierte lernt normales Verhalten und meldet Abweichungen.
- Eine Suricata-Regel definiert Aktion, Protokoll, Muster und einen Schwellenwert für die Auslösung.
- Threshold-Werte unterscheiden einen echten Scan oder Flood von gewöhnlichem Verkehr.
- Jede neue Regel sollte mit einem bekannten, bewusst erzeugten Auslöser getestet werden.

Kapitel 7: Die Angriffe dieser Reihe wiedererkennen

Lernziele

- Du erkennst die Spuren von hping3, Nmap, Metasploit und Burp Suite in Logs und Alarmen.
- Du kannst zu jeder Technik eine passende Erkennungsidee formulieren.
- Du verstehst, warum manche Techniken leichter zu erkennen sind als andere.

7.1 hping3: SYN-Scans und Floods

Beispiel 7.1: hping3-Portscan im Suricata-Alarm

```
alert tcp any any -> $HOME_NET any (msg:"Möglicher Portscan"; flags:S; \
  threshold:type threshold, track by_src, count 20, seconds 10; sid:1000001;)
```

Derselbe Alarm aus Kapitel 6.2 erfasst sowohl einen hping3-Einzelscan über mehrere Ports (hping3-Handbuch, Kapitel 5) als auch einen vergleichbaren Nmap-Scan (7.2) – aus Netzwerksicht erzeugen beide ein ähnliches Muster vieler SYN-Pakete in kurzer Zeit.

7.2 Nmap: Scan-Geschwindigkeit als Erkennungsmerkmal

Gut zu wissen

Ein `-T4`- oder `-T5`-Scan (Nmap-Handbuch, Kapitel 6.1) erzeugt deutlich mehr Pakete in kürzerer Zeit als derselbe Scan mit `-T2` – und ist damit aus Verteidigersicht leichter zu erkennen. Dieselbe Geschwindigkeit, die einem Angreifer Zeit spart, macht ihn für ein Schwellenwert-basiertes Erkennungssystem auffälliger.

7.3 Brute-Force: Login-Versuche über SSH, Web oder Metasploit-Auxiliary

Beispiel 7.2: SSH-Brute-Force im Systemprotokoll

```
$ grep "Failed password" /var/log/auth.log | awk '{print $11}' | sort | uniq -c | sort -rn
```

Dieser Befehl zählt fehlgeschlagene Login-Versuche nach Quelladresse – unabhängig davon, ob sie mit Hydra, einem Metasploit-Login-Scanner (Metasploit-Handbuch, Kapitel 6.3) oder dem Burp-Suite-Intruder (Burp-Suite-Handbuch, Kapitel 6) erzeugt wurden. Alle drei Werkzeuge hinterlassen auf Protokollebene ein nahezu identisches Muster: viele Fehlversuche derselben Quelle in kurzer Zeit.

7.4 Metasploit: ein Exploit-Versuch im Log

Beispiel 7.3: vsftpd-Backdoor-Verbindungsversuch im Firewall-/Verbindungslog (Konzept)

```
Eingehende Verbindung auf Port 21, gefolgt von einer neuen,
ausgehenden Verbindung auf einem ungewöhnlichen, hohen Port
-> typisches Muster einer erfolgreichen Shell-Öffnung nach einem Exploit
```

Gut zu wissen

Ein erfolgreicher Exploit wie die vsftpd-Backdoor (Metasploit-Handbuch, Kapitel 7.1) erzeugt oft ein auffälliges Folgemuster: kurz nach der ursprünglichen Verbindung entsteht eine neue, unerwartete Verbindung auf einem Port, der vorher nicht in Benutzung war. Dieses Muster lässt sich unabhängig vom konkreten Exploit erkennen, ohne die jeweilige Schwachstelle im Detail zu kennen.

7.5 Burp Suite: SQL-Injection und XSS im Webserver-Log

Beispiel 7.4: Typische Angriffsmuster im Webserver-Log

```
$ grep -E "union select|<script|' or '1'='1" /var/log/apache2/access.log
```

Dieselben Testwerte, die im Ethical-Hacking- und Burp-Suite-Handbuch als Angriffsbeispiel dienen, lassen sich hier als einfache Textmuster im Log wiederfinden – eine der am leichtesten zu erkennenden Kategorien dieses Kapitels, weil die Angriffswerte selbst ungewöhnliche, auffällige Zeichenfolgen enthalten.

7.6 Warum manche Techniken schwerer zu erkennen sind

Technik	Erkennungsschwierigkeit	Grund
Nmap-Scan mit `-T5`	gering	viele Pakete in kurzer Zeit, deutliches Muster
Nmap-Scan mit `-T0`/`-T1`	hoch	ein Paket alle Minuten, kaum von normalem Verkehr zu unterscheiden
SQL-Injection-Testwert	gering	ungewöhnliche Zeichenfolge im Klartext sichtbar
Sudo-Fehlkonfiguration ausnutzen (Linux-PrivEsc-Handbuch)	hoch	der Befehl selbst ist regulär erlaubt, nur sein Kontext ist verdächtig

TIPP – Profi-Trick

Je „leiser" eine Technik absichtlich gestaltet ist (langsames Timing, legitime Werkzeuge wie in GTFOBins, Linux-PrivEsc-Handbuch, Kapitel 5), desto mehr verschiebt sich die Erkennung von reinen Mustern hin zu einer Bewertung des Kontexts – wer tut was, wann, und passt das zum normalen Verhalten dieses Kontos?

Zusammenfassung

Zusammenfassung

- hping3- und Nmap-Scans erzeugen ein ähnliches, über Schwellenwerte erkennbares Paketmuster.
- Brute-Force-Versuche mit Hydra, Metasploit oder Burp-Suite-Intruder hinterlassen auf Protokollebene fast identische Spuren.
- Ein erfolgreicher Exploit zeigt sich oft an einem auffälligen Folgemuster neuer, unerwarteter Verbindungen.
- Langsame, legitime Werkzeuge nutzende Techniken sind deutlich schwerer zu erkennen als schnelle, auffällige Muster.

Kapitel 8: Incident Response – Phasen und Playbooks

Lernziele

- Du kennst die sechs klassischen Phasen der Incident Response.
- Du kannst ein einfaches Playbook für ein konkretes Szenario erstellen.
- Du verstehst, warum Dokumentation während, nicht erst nach einem Vorfall beginnt.

8.1 Die sechs Phasen

Phase	Kernfrage
Preparation	Sind Werkzeuge, Kontakte und Playbooks im Voraus vorbereitet?
Identification	Ist tatsächlich ein Vorfall eingetreten, und was ist betroffen?
Containment	Wie wird eine weitere Ausbreitung sofort gestoppt?
Eradication	Wie wird die eigentliche Ursache vollständig entfernt?
Recovery	Wie wird der Normalbetrieb sicher wiederhergestellt?
Lessons Learned	Was wird aus diesem Vorfall für die Zukunft gelernt?

Beispiel 8.1: Die Reihenfolge am Beispiel eines SYN-Flood-Alarms (Konzept)

```
Identification -> Suricata-Alarm aus Kapitel 6.3 bestätigt sich als echt
Containment    -> betroffene Quelladresse temporär blockieren
Eradication    -> Ursache klären: eigener Testlauf, oder echter externer Angriff?
Recovery       -> Normalbetrieb wiederherstellen, Blockade ggf. wieder aufheben
Lessons Learned -> Schwellenwert der Erkennungsregel ggf. anpassen
```

8.2 Ein einfaches Playbook erstellen

Ein **Playbook** ist eine im Voraus festgelegte, schrittweise Anleitung für ein wiederkehrendes Szenario – damit im Ernstfall nicht erst überlegt werden muss, sondern direkt gehandelt werden kann.

Beispiel 8.2: Playbook-Gerüst für "Mehrere fehlgeschlagene SSH-Logins" (Konzept)

```
1. Auslöser: SIEM-Alarm aus Kapitel 5.4 (mehr als 5 Fehlversuche in 5 Minuten)
2. Sofortmaßnahme: betroffenes Konto temporär sperren
3. Prüfung: Quelladresse bekannt und vertrauenswürdig, oder unbekannt?
4. Eskalation: bei unbekannter Quelle zusätzliche Systeme auf dieselbe Adresse prüfen
5. Dokumentation: Zeitpunkt, Quelle, betroffenes Konto, ergriffene Maßnahme
```

TIPP – Profi-Trick

Ein gutes Playbook ist kurz genug, dass es unter Zeitdruck tatsächlich gelesen und befolgt wird. Ein zehnseitiges Dokument für ein Szenario, das in wenigen Minuten entschieden werden muss, verfehlt seinen Zweck.

8.3 Dokumentation beginnt während des Vorfalls

WARNUNG – Sicherheitsrisiko

Dokumentation, die erst nach der Behebung eines Vorfalls aus dem Gedächtnis rekonstruiert wird, verliert zuverlässig Details – genaue Zeitpunkte, die Reihenfolge der Schritte, welche Information wann vorlag. Ein einfaches, chronologisches Protokoll während des gesamten Vorfalls ist deutlich verlässlicher.

Beispiel 8.3: Ein einfaches Vorfall-Protokoll (Konzept)

```
14:02 - Suricata-Alarm "Möglicher Portscan" von 192.168.56.101
14:04 - Bestätigt: Quelle ist bekannte, autorisierte Test-VM
14:05 - Keine weitere Maßnahme nötig, als eigener Testlauf eingestuft
```

Zusammenfassung

Zusammenfassung

- Preparation, Identification, Containment, Eradication, Recovery und Lessons Learned bilden die sechs Phasen der Incident Response.
- Ein Playbook legt für ein wiederkehrendes Szenario im Voraus fest, was im Ernstfall zu tun ist.
- Playbooks sollten kurz und unter Zeitdruck tatsächlich nutzbar sein.
- Dokumentation während des Vorfalls ist zuverlässiger als eine nachträgliche Rekonstruktion.

Kapitel 9: Hardening – Systeme absichtlich widerstandsfähiger machen

Lernziele

- Du wendest das Minimalprinzip auf ein eigenes System an.
- Du härtest SSH-Zugänge gegen die im Ethical-Hacking-Handbuch gezeigten Brute-Force-Techniken.
- Du verstehst Hardening als Gegenstück zur OWASP-Kategorie Security Misconfiguration.

9.1 Das Minimalprinzip

Hardening bedeutet, ein System bewusst auf das Nötigste zu reduzieren: weniger aktive Dienste, weniger offene Ports, weniger installierte Software bedeuten weniger mögliche Angriffsfläche.

Beispiel 9.1: Aktive Dienste eines Systems prüfen

```
$ systemctl list-units --type=service --state=running
```

Gut zu wissen

Dieses Prinzip ist das direkte Gegenstück zur OWASP-Kategorie Security Misconfiguration (OWASP-Handbuch, Kapitel 4): Dort wird beschrieben, wie überflüssige, aktive Komponenten zum Risiko werden; Hardening ist die praktische Umsetzung der dort empfohlenen Gegenmaßnahme.

9.2 SSH gezielt härten

Beispiel 9.2: SSH-Konfiguration härten (Auszug aus /etc/ssh/sshd_config)

```
PermitRootLogin no
PasswordAuthentication no
MaxAuthTries 3
```

Einstellung	Wirkung gegen welche Technik
`PermitRootLogin no`	verhindert direkten root-Login, erzwingt den Umweg über ein normales Konto und `sudo`
`PasswordAuthentication no`	macht Passwort-Brute-Force-Versuche (Ethical-Hacking-Handbuch, Kapitel 6.4) wirkungslos, da nur Schlüssel akzeptiert werden
`MaxAuthTries 3`	begrenzt die Anzahl der Versuche pro Verbindung

Beispiel 9.3: Fail2ban als ergänzende Maßnahme

```
$ sudo apt install fail2ban
```

Fail2ban beobachtet Protokolle wie `/var/log/auth.log` (Kapitel 4.2) und sperrt eine Quelladresse automatisch nach einer konfigurierbaren Anzahl Fehlversuche – eine praktische, automatisierte

Umsetzung des in Kapitel 8.2 gezeigten Playbooks.

9.3 Hardening gegen die anderen Bände dieser Reihe

Härtungsmaßnahme	Wirkt gegen
SYN Cookies aktivieren	SYN-Flood (hping3-Handbuch, Kapitel 8.3)
Fehlerseiten ohne Versionsangabe konfigurieren	Versionserkennung (Nmap-Handbuch, Kapitel 5.1)
Moderne Hash-Verfahren wie bcrypt nutzen	Passwort-Cracking (John-the-Ripper-/Hashcat-Handbuch)
sudo-Regeln eng und konkret statt mit Platzhaltern formulieren	Sudo-Fehlkonfiguration (Linux-PrivEsc-Handbuch, Kapitel 6)
Parametrisierte Datenbankabfragen verwenden	SQL-Injection (Ethical-Hacking-/Burp-Suite-Handbuch)

TIPP – Profi-Trick

Diese Tabelle lässt sich als Prüfliste verwenden: Für jede in dieser Reihe gezeigte Angriffstechnik existiert mindestens eine konkrete, bereits an anderer Stelle dieser Bücher genannte Gegenmaßnahme.

Zusammenfassung

Zusammenfassung

- Hardening reduziert ein System bewusst auf das Nötigste, um die Angriffsfläche zu verkleinern.
- Deaktivierter root-Login, reine Schlüssel-Authentifizierung und Fail2ban härten SSH gezielt gegen Brute-Force.
- Hardening ist die praktische Umsetzung dessen, was die OWASP-Kategorie Security Misconfiguration beschreibt.
- Für jede Angriffstechnik dieser Reihe existiert eine bereits an anderer Stelle genannte, konkrete Gegenmaßnahme.

Kapitel 10: Praxisteil – Laboraufbau und geführte Übungen

Lernziele

- Du baust das für dieses Buch nötige Labor auf.
- Du arbeitest acht Übungen durch, die jeweils eine Angriffstechnik aus einem anderen Band erkennen und darauf reagieren.
- Du erstellst am Ende eine eigene, kleine Sammlung an Erkennungsregeln und Playbooks.

10.1 Laboraufbau

Dieses Buch nutzt das um eine Monitoring-VM erweiterte Labor aus Kapitel 3: Kali-VM, Metasploitable-VM und die neue Monitoring-VM mit Suricata, alle im selben Internal Network.

10.2 Checkliste: sichere Laborumgebung

Checkliste 10.1: Vor jeder Übung

```
[ ] Monitoring-VM läuft und zeigt denselben Verkehr wie die anderen VMs
[ ] Suricata-Alarme werden live mitverfolgt (tail -f fast.log)
[ ] Jede Übung wird in einem eigenen Vorfall-Protokoll festgehalten (Kapitel 8.3)
```

10.3 Übungen

Jede Übung folgt demselben Schema: Ziel, Voraussetzungen, Durchführung, erwartetes Ergebnis, Auswertung und Fehlerbehebung.

Übung 1: Einen hping3-Scan erkennen

Ziel: Die Erkennungsregel aus Kapitel 6.2 gegen echten Verkehr testen. **Voraussetzungen:** Suricata läuft auf der Monitoring-VM. **Durchführung:** Führe von der Kali-VM aus `sudo hping3 --scan 1-1000 -S 192.168.56.102` aus (hping3-Handbuch, Beispiel 5.3). **Erwartetes Ergebnis:** Ein Suricata-Alarm „Möglicher Portscan" erscheint in `fast.log`. **Auswertung:** Notiere Zeitpunkt, Quelladresse und ausgelöste Regel-ID im Vorfall-Protokoll. **Fehlerbehebung:** Kein Alarm? Prüfe, ob die Monitoring-VM tatsächlich denselben Verkehr sieht (Promiscuous Mode, Kapitel 3.1).

Übung 2: Scan-Timing und Erkennbarkeit vergleichen

Ziel: Kapitel 7.6 praktisch nachvollziehen. **Voraussetzungen:** wie Übung 1. **Durchführung:** Wiederhole denselben Scan einmal mit `-T5` und einmal mit `-T1` (Nmap-Handbuch, Kapitel 6.1). **Erwartetes Ergebnis:** Der `-T5`-Scan löst den Alarm zuverlässig aus, der `-T1`-Scan möglicherweise gar nicht. **Auswertung:** Erkläre schriftlich, warum der Schwellenwert aus Beispiel 6.1 bei langsamem Timing nicht greift. **Fehlerbehebung:** Löst auch `-T1` einen Alarm aus, prüfe den konfigurierten Zeitraum deiner Regel – er könnte großzügiger sein als in Beispiel 6.1 angenommen.

Übung 3: SSH-Brute-Force im Log und mit Fail2ban

Ziel: Erkennung und Gegenmaßnahme gemeinsam durchlaufen. **Voraussetzungen:** Metasploitable-VM mit SSH, eine kleine Testwortliste. **Durchführung:** Führe einige absichtlich falsche SSH-Login-Versuche gegen die Metasploitable-VM aus, werte danach `/var/log/auth.log` aus (Beispiel 4.1, 7.2), und installiere anschließend Fail2ban (Beispiel 9.3). **Erwartetes Ergebnis:** Die Fehlversuche erscheinen im Log; nach der Fail2ban-Installation wird die Quelladresse nach wenigen Versuchen automatisch gesperrt. **Auswertung:** Vergleiche die Anzahl der Versuche vor und nach der Sperrung. **Fehlerbehebung:** Keine Sperrung? Prüfe die Fail2ban-Konfiguration für den SSH-Jail (`/etc/fail2ban/jail.local`).

Übung 4: SQL-Injection im Webserver-Log finden

Ziel: Kapitel 7.5 praktisch anwenden. **Voraussetzungen:** DVWA mit Apache-Zugriffsprotokoll. **Durchführung:** Führe den SQL-Injection-Test aus dem Ethical-Hacking- oder Burp-Suite-Handbuch erneut aus und durchsuche danach `access.log` (Beispiel 7.4). **Erwartetes Ergebnis:** Der Injection-Testwert erscheint lesbar im Log-Eintrag der betreffenden Anfrage. **Auswertung:** Notiere, wie eindeutig dieses Muster im Vergleich zu einem gewöhnlichen Seitenaufruf ist. **Fehlerbehebung:** Kein Treffer? Prüfe, ob DVWA tatsächlich über den protokollierenden Apache-Server läuft, statt über einen separaten Entwicklungsserver.

Übung 5: Einen Metasploit-Exploit-Versuch beobachten

Ziel: Kapitel 7.4 praktisch nachvollziehen. **Voraussetzungen:** Metasploit-Handbuch, Kapitel 7.1 (vsftpd-Backdoor) wiederholbar. **Durchführung:** Starte auf der Monitoring-VM einen Wireshark-Mitschnitt (Wireshark-Handbuch, Kapitel 3), führe danach den Exploit aus Metasploit aus. **Erwartetes Ergebnis:** Im Mitschnitt erscheint die ursprüngliche FTP-Verbindung, gefolgt von einer neuen, unerwarteten Verbindung auf einem anderen Port. **Auswertung:** Vergleiche das beobachtete Muster mit der Beschreibung in Beispiel 7.3. **Fehlerbehebung:** Kein Folgemuster sichtbar? Prüfe, ob der Exploit tatsächlich erfolgreich eine Sitzung geöffnet hat (`sessions -l` in msfconsole).

Übung 6: Einen SYN-Flood-Alarm richtig einordnen

Ziel: Kapitel 6.3 und 8.1 gemeinsam anwenden. **Voraussetzungen:** hping3-Handbuch, Kapitel 8.1.1 (ratenbegrenzter Test), Checkliste 10.1 dieses Buches. **Durchführung:** Führe den ratenbegrenzten SYN-Test aus dem hping3-Handbuch aus und durchlaufe danach die Phasen aus Beispiel 8.1 schriftlich. **Erwartetes Ergebnis:** Ein Suricata-Alarm aus Beispiel 6.2, gefolgt von einer vollständigen, dokumentierten Phasenabfolge. **Auswertung:** Vergleiche deine Containment-Entscheidung mit der in Beispiel 8.1 vorgeschlagenen. **Fehlerbehebung:** Kein Alarm trotz hoher Paketrate? Prüfe den Schwellenwert deiner Regel gegen die tatsächlich erzeugte Paketrate.

Übung 7: Ein eigenes Playbook schreiben

Ziel: Kapitel 8.2 auf ein selbst gewähltes Szenario übertragen. **Voraussetzungen:** Ergebnisse aus Übung 1-6. **Durchführung:** Wähle eine der vorherigen Übungen und formuliere dafür ein eigenes, fünfstufiges Playbook nach dem Muster aus Beispiel 8.2. **Erwartetes Ergebnis:** Ein kurzes, im Ernstfall tatsächlich nutzbares Playbook. **Auswertung:** Lass eine andere Person dein Playbook lesen und einschätzen, ob es ohne Rückfragen befolgbar wäre. **Fehlerbehebung:** Zu lang oder zu vage? Kürze auf die tatsächlich notwendigen Entscheidungsschritte.

Übung 8: Eine Hardening-Maßnahme umsetzen und erneut testen

Ziel: Den vollständigen Kreislauf aus Erkennung und Gegenmaßnahme schließen. **Voraussetzungen:** Ergebnis aus Übung 3. **Durchführung:** Setze die SSH-Härtung aus Beispiel 9.2 auf der Metasploitable-VM um (sofern die VM das zulässt, sonst auf einer eigenen Test-VM) und wiederhole den Brute-Force-Versuch aus Übung 3. **Erwartetes Ergebnis:** Der Brute-Force-Versuch schlägt nun durchgehend fehl, unabhängig vom Passwort. **Auswertung:** Dokumentiere Vorher-Nachher-Ergebnis als abschließenden Beleg für die Wirksamkeit der Maßnahme. **Fehlerbehebung:** Härtung ohne Wirkung? Prüfe, ob `sshd` nach der Konfigurationsänderung tatsächlich neu gestartet wurde.

Zusammenfassung

Zusammenfassung

- Die um eine Monitoring-VM erweiterte Laborumgebung reicht für alle acht Übungen aus.
- Jede Übung verbindet eine bereits aus einem anderen Band bekannte Angriffstechnik mit ihrer Erkennung und Gegenmaßnahme.
- Die letzten beiden Übungen schließen den Kreis von der Erkennung über das Playbook bis zur gehärteten Gegenmaßnahme.

Kapitel 11: Troubleshooting, Spickzettel, Glossar und Ressourcen

Lernziele

- Du kannst die häufigsten Probleme beim Aufbau eines eigenen Monitoring-Labors einordnen und beheben.
- Du hast einen kompakten Spickzettel für den Alltag zur Hand.
- Du kennst weiterführende Ressourcen für die Vertiefung.

11.1 Häufige Probleme

Symptom	Wahrscheinliche Ursache	Lösung
Monitoring-VM sieht keinen fremden Verkehr	Netzwerkschnittstelle nicht im Promiscuous Mode, oder falsches virtuelles Netzwerk	Schnittstellenkonfiguration und Netzwerkzuordnung prüfen (Kapitel 3.1)
Suricata startet, aber keine Alarme erscheinen	veraltete oder fehlende Regeln	`suricata-update` erneut ausführen (Beispiel 3.2)
Zu viele Fehlalarme bei normalem Verkehr	Schwellenwert zu niedrig angesetzt	`threshold`-Werte in der Regel anheben (Kapitel 6.2)
syslog-Weiterleitung kommt nicht an	Firewall blockiert Port 514, oder falsche Zielsyntax	Konnektivität mit `nc -u <ip> 514` testen
Fail2ban sperrt gar nicht	falscher Log-Pfad oder falsches Filtermuster in der Jail-Konfiguration	`fail2ban-client status sshd` zur Diagnose nutzen

11.2 Spickzettel

Beispiel 11.1: Die wichtigsten Blue-Team-Befehle auf einen Blick

```
# Logs durchsuchen
grep "Failed password" /var/log/auth.log
grep -E "union select|<script" /var/log/apache2/access.log

# Suricata
sudo suricata-update
sudo tail -f /var/log/suricata/fast.log
# Aktive Dienste prüfen
systemctl list-units --type=service --state=running

# Fail2ban
sudo fail2ban-client status
sudo fail2ban-client status sshd

# SSH-Härtung testen
ssh -v <ziel>   # zeigt, welche Authentifizierungsmethoden akzeptiert werden
```

11.3 Glossar

- **Containment** – die Incident-Response-Phase, die eine weitere Ausbreitung eines Vorfalls sofort stoppt.
- **Defense in Depth** – das Prinzip mehrerer, unabhängig wirkender Sicherheitsschichten.
- **Fail2ban** – ein Werkzeug, das Protokolle beobachtet und auffällige Quelladressen automatisiert sperrt.
- **Hardening** – das bewusste Reduzieren eines Systems auf das für seinen Zweck Nötigste.
- **MITRE ATT&CK** – eine öffentlich gepflegte Wissensbasis bekannter Angreifertaktiken und -techniken.
- **Playbook** – eine im Voraus festgelegte, schrittweise Anleitung für ein wiederkehrendes Vorfallszenario.
- **SIEM** – Security Information and Event Management, die zentrale Sammlung und Auswertung von Logs.
- **Signaturbasierte Erkennung** – Erkennung anhand bekannter, dokumentierter Muster, im Gegensatz zur anomaliebasierten Erkennung.
- **SOC** – Security Operations Center, die organisatorische Einheit, die laufende Überwachung übernimmt.

11.4 Weiterführende Ressourcen

Ressource	Inhalt
attack.mitre.org	die vollständige, durchsuchbare MITRE-ATT&CK-Wissensbasis
Suricata-Dokumentation (suricata.io)	vollständige Regelsyntax und Konfigurationsreferenz
Elastic- bzw. Wazuh-Dokumentation	Aufbau und Betrieb eines eigenen SIEM
Alle neun vorherigen Bände dieser Reihe	die Angriffstechniken, die in diesem Buch aus Verteidigersicht behandelt werden
TryHackMe / Blue-Team-Labs-Online	legale Übungsplattformen mit eigenem Schwerpunkt auf Detection und Incident Response

TIPP – Profi-Trick

TryHackMe bietet neben den bereits in anderen Bänden erwähnten offensiven Räumen auch einen eigenen, wachsenden Bereich speziell für Blue-Team-Themen – eine naheliegende Fortsetzung nach diesem Buch.

Zusammenfassung

Zusammenfassung

- Die häufigsten Probleme betreffen Netzwerkkonfiguration, veraltete Erkennungsregeln und falsch kalibrierte Schwellenwerte.
- Der Spickzettel verbindet Log-Auswertung, Suricata, Dienstübersicht und Fail2ban zu einem kompakten Werkzeugsatz.

- MITRE ATT&CK, die Suricata- und SIEM-Dokumentation sowie die anderen neun Bände dieser Reihe sind die wichtigsten Anschlussstellen zum Weiterlernen.

Verzeichnis der Befehlsbeispiele

Beispiel 1.1: Der Kreislauf zwischen Red und Blue (Konzept) … Seite 7
Beispiel 2.1: Typische Schichten (Konzept) … Seite 9
Beispiel 2.2: Dieselbe Kette, umgekehrt gelesen … Seite 9
Beispiel 2.3: Eine ATT&CK-Technik nachschlagen (Konzept) … Seite 10
Beispiel 3.1: Laboraufbau für dieses Buch (Konzept) … Seite 11
Beispiel 3.2: Suricata auf der Monitoring-VM installieren … Seite 11
Beispiel 3.3: rsyslog als zentralen Log-Sammelpunkt einrichten (Konzept) … Seite 11
Beispiel 4.1: Fehlgeschlagene Anmeldeversuche finden … Seite 13
Beispiel 4.2: sudo-Nutzung nachvollziehen … Seite 13
Beispiel 4.3: Auffällige Zugriffsmuster im Webserver-Log … Seite 13
Beispiel 5.1: Warum ein verteilter Angriff in Einzel-Logs unsichtbar bleibt (Konzept) … Seite 15
Beispiel 5.2: Die drei Grundbestandteile eines SIEM (Konzept) … Seite 15
Beispiel 5.3: Mehrere fehlgeschlagene Logins von derselben Quelle finden (Konzept) … Seite 15
Beispiel 5.4: Eine Abfrage in eine wiederkehrende Regel umwandeln (Konzept) … Seite 16
Beispiel 6.1: Eine Regel zur Erkennung eines Nmap-SYN-Scans (Konzept) … Seite 17
Beispiel 6.2: Eine Regel zur Erkennung eines SYN-Floods (Konzept, vergleiche hping3-Handbuch, Kapitel 8) … Seite 18
Beispiel 6.3: Suricata-Alarme live verfolgen … Seite 18
Beispiel 7.1: hping3-Portscan im Suricata-Alarm … Seite 19
Beispiel 7.2: SSH-Brute-Force im Systemprotokoll … Seite 19
Beispiel 7.3: vsftpd-Backdoor-Verbindungsversuch im Firewall-/Verbindungslog (Konzept) … Seite 19
Beispiel 7.4: Typische Angriffsmuster im Webserver-Log … Seite 20
Beispiel 8.1: Die Reihenfolge am Beispiel eines SYN-Flood-Alarms (Konzept) … Seite 21
Beispiel 8.2: Playbook-Gerüst für "Mehrere fehlgeschlagene SSH-Logins" (Konzept) … Seite 21
Beispiel 8.3: Ein einfaches Vorfall-Protokoll (Konzept) … Seite 22
Beispiel 9.1: Aktive Dienste eines Systems prüfen … Seite 23
Beispiel 9.2: SSH-Konfiguration härten (Auszug aus /etc/ssh/sshd_config) … Seite 23
Beispiel 9.3: Fail2ban als ergänzende Maßnahme … Seite 23
Checkliste 10.1: Vor jeder Übung … Seite 25
Beispiel 11.1: Die wichtigsten Blue-Team-Befehle auf einen Blick … Seite 28

Index

Anomaliebasiert – 29
Blue Team – 5
Containment – 26, 29
Defense in Depth – 9, 29
Fail2ban – 23, 26, 29
Hardening – 23, 24, 27, 29
Incident Response – 5
MITRE ATT&CK – 10, 29
Playbook – 21, 24, 26, 29
SIEM – 11, 15, 16, 29
Signaturbasiert – 17, 29
SOC – 29
Suricata – 11, 17, 18, 19, 25, 26

BLUE TEAM & DEFENSE

Was jeder Angriff dieser Reihe im Log hinterlässt

Neun Bände dieser Reihe zeigen den Angriff. Dieses Handbuch dreht die Blickrichtung um: Es erklärt Logging, SIEM, Intrusion Detection, Incident Response und Hardening, und zeigt in einem eigenen Kapitel konkret, wie sich hping3-Scans, Nmap-Scans, Brute-Force-Versuche und Metasploit-Exploits in Logs und Erkennungsregeln wiederfinden lassen.

DAS ERWARTET DICH

- Defense in Depth, die Kill Chain aus Verteidigersicht und MITRE ATT&CK;
- Logging-Grundlagen und der Aufbau eines eigenen SIEM
- Intrusion Detection mit Suricata, von der Regel bis zum Alarm
- Ein eigenes Kapitel: die Angriffe aus hping3, Nmap, Metasploit und Burp Suite wiedererkennen
- Incident-Response-Phasen, Playbooks, Hardening, 8 geführte Übungen und Glossar

Für wen?

Leser:innen aller Bände dieser Reihe, die neben der Angreifer- auch die Verteidigerperspektive kennenlernen möchten, sowie Studierende und Auszubildende, die sich auf Detection und Incident Response vorbereiten.

32 Seiten · Stand Oktober 2026 · Die Gegenseite der gesamten Buchreihe für IT-Sicherheit

Hinweis: Keine Rechts- oder Anlageberatung. Marken- und Produktnamen gehören ihren jeweiligen Inhabern.